

REvil - GOLD SOUTHFIELD LAB

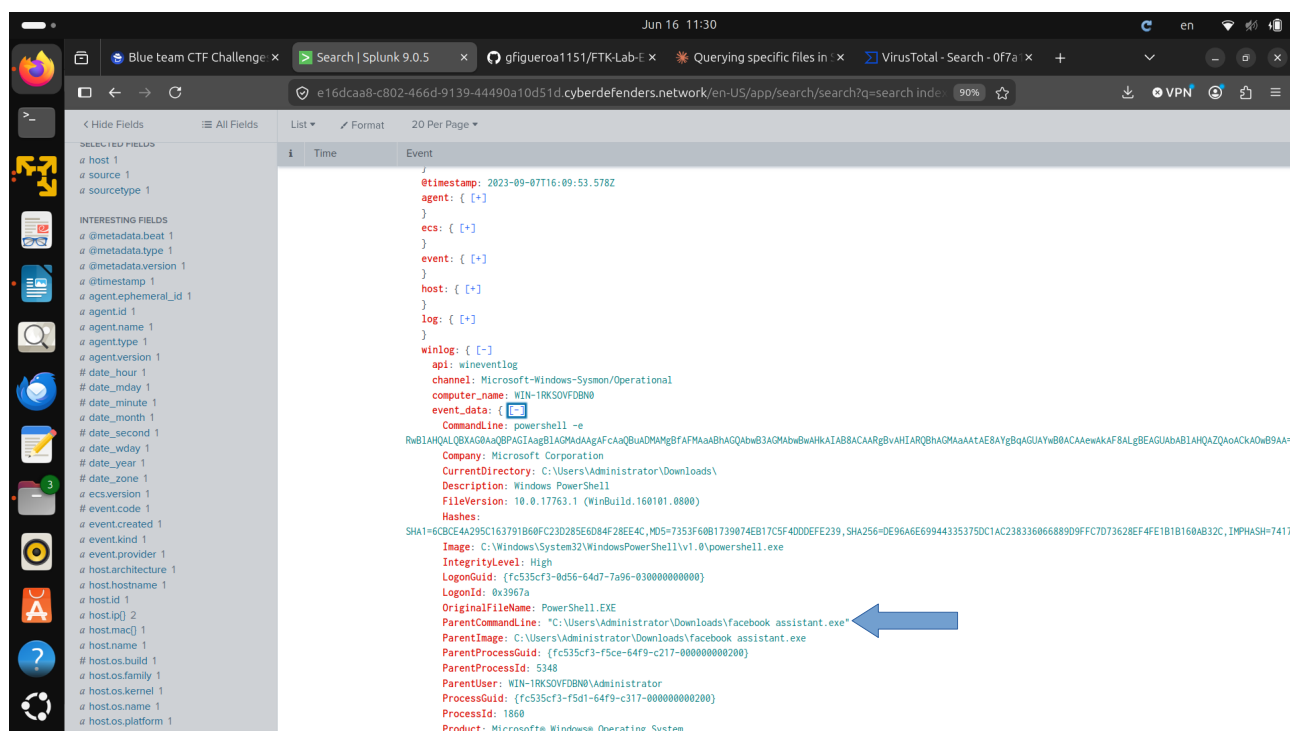
CyberDefenders Lab

06/16/26

Scenario: I am a Threat Hunter working for a Cybersecurity consulting firm. One of my clients has been recently affected by a ransomware attack that caused the encryption of multiple of their employees' machines. The affected users have reported encountering a ransom note on their desktop and a changed desktop background. I'm tasked with using Splunk SIEM containing Sysmon event logs of one of the encrypted machines to extract as much information as possible.

Question 1: To begin your investigation, can you identify the filename of the note that the ransomware left behind?

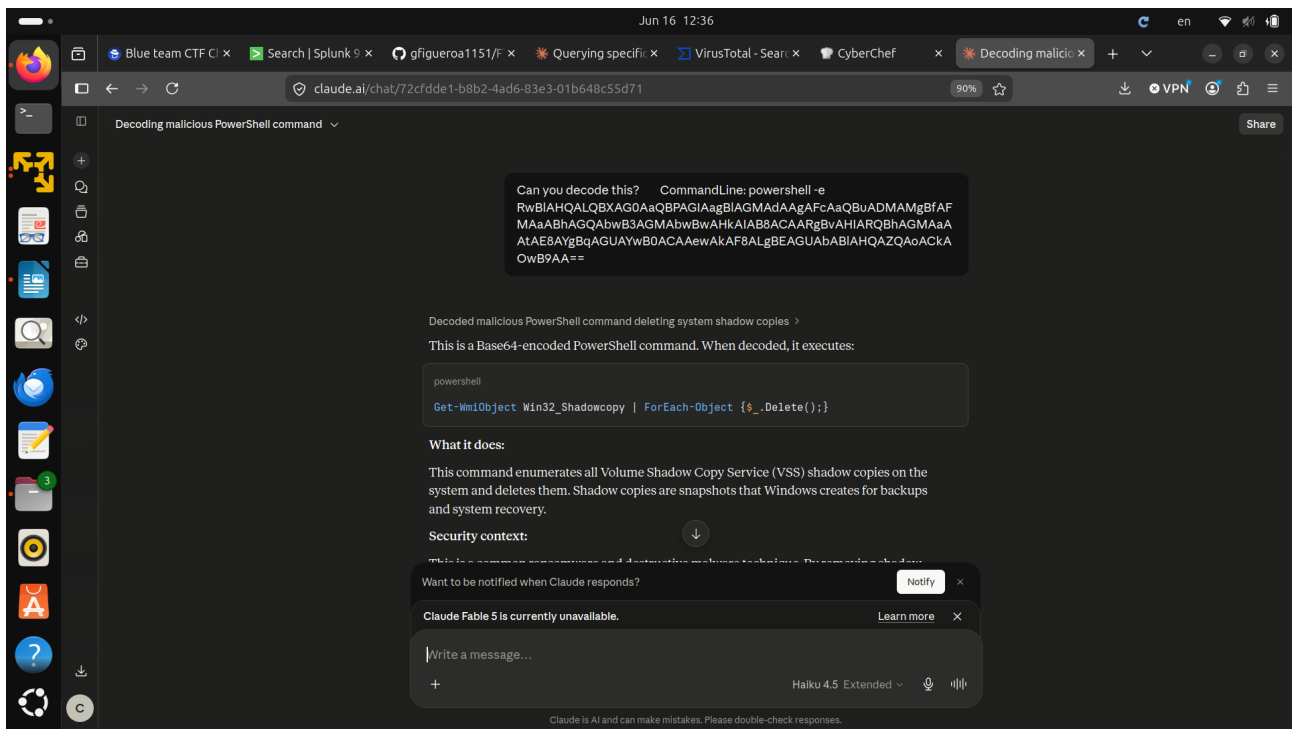
To identify the filename of the note, I first had to get the query set up. For this, I started with **index=revil**. From there, I checked the interesting fields, and under **winlog.event_data.CommandLine**, I see a very interesting field that facebook assistance.exe being placed in the downloads folder. I added that to the query, checked the log, and can see a powershell was being ran alongside the download.



The screenshot shows a Splunk search interface with the following details:

- Search Bar:** e16dcaa8-c802-466d-9139-44490a10d51d.cyberdefenders.network/en-US/app/search/search?q=search index=revil
- Fields List:** On the left, under 'INTERESTING FIELDS', the field `winlog.event_data.CommandLine` is selected.
- Event Data:** The main panel displays a Sysmon event log entry with the following fields:
 - `@timestamp:` 2023-09-07T16:09:53.578Z
 - `agent:` { [+] }
 - `ecs:` { [+] }
 - `event:` { [+] }
 - `host:` { [+] }
 - `log:` { [+] }
 - `winlog:` { [-] }
 - `api:` wineventlog
 - `channel:` Microsoft-Windows-Sysmon/Operational
 - `computer_name:` WIN-1RKSOVDBN0
 - `event_data:` { [+] }
 - `CommandLine:` powershell -e [obfuscated]
 - `Company:` Microsoft Corporation
 - `CurrentDirectory:` C:\Users\Administrator\Downloads\
 - `Description:` Windows PowerShell
 - `FileVersion:` 10.0.17763.1 (WinBuild.160101.0800)
 - `Hashes:` SHA1=6CBCE4A295C163791B60FC23D285E6D84F28EE4C, MD5=7353F6081739074EB17C5F400DEF239, SHA256=DE96A6E69944335375DCA23833606688909FFC7073628EF4FE181B160AB32C, IMPHASH=7417;
 - `Image:` C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
 - `IntegrityLevel:` High
 - `LogonGuid:` {fc535cf3-0d56-64d7-7a96-030000000000}
 - `LogonId:` 0x3967a
 - `OriginalFileName:` PowerShell.EXE
 - `ParentCommandLine:` "C:\Users\Administrator\Downloads\facebook assistant.exe"
 - `ParentImage:` C:\Users\Administrator\Downloads\facebook assistant.exe
 - `ParentProcessGuid:` {fc535cf3-f5ce-64f9-c217-000000000200}
 - `ParentProcessId:` 5348
 - `ParentUser:` WIN-1RKSOVDBN0\Administrator
 - `ProcessGuid:` {fc535cf3-f5d1-64f9-c317-000000000200}
 - `ProcessId:` 1860
 - `Product:` Microsoft Windows Operating System

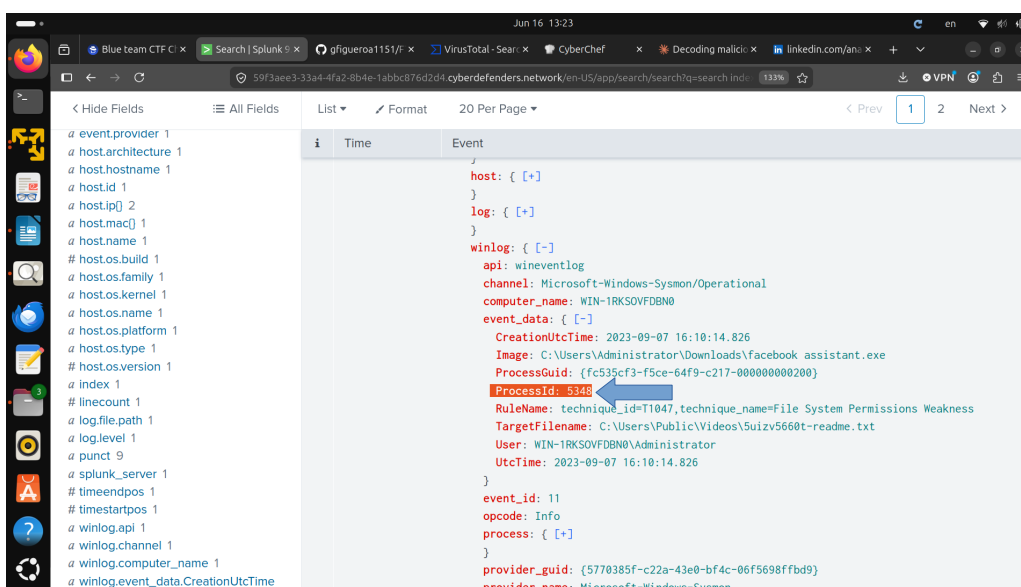
Before continuing, I can see that the powershell command is obfuscated, so I copied it and sent it to Claude AI, which decrypted it and showed that this command was attempting to prevent system restores, eliminate backup recoveries, and make it much more difficult to recover files from ransomware attack.



After taking note of this, I went into splunk query and did **index=revil “facebook assistant.exe”**, from the logs, we can see that the ransomware facebook assistant.exe is creating the file 5uizv5660t-readme.txt. This was also placed in many other folders around 2023-09-07 16:10:14.

Question 2: After identifying the ransom note, the next step is to pinpoint the source. What's the process ID of the ransomware that's likely involved?

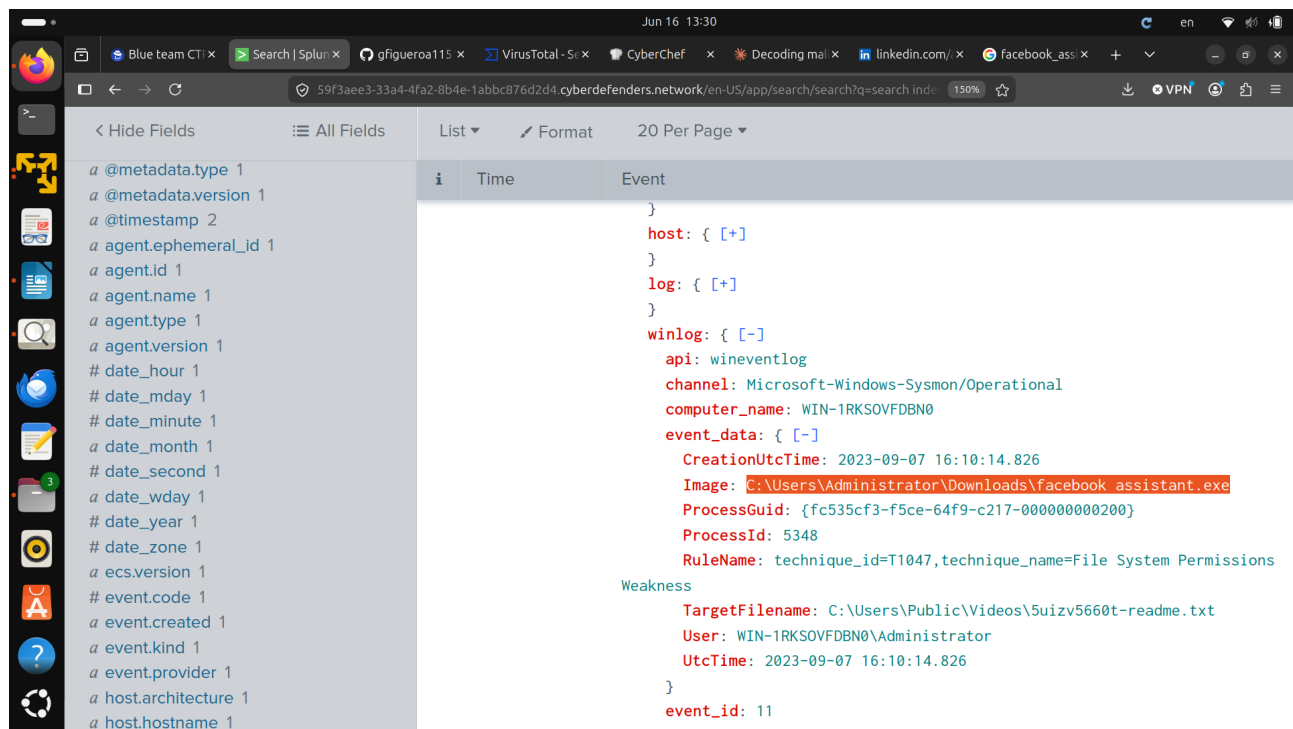
Within the same log of the **index=revil “facebook assistant.exe”**, we can see that the process ID of the ransomware is 5348



Question

3: Having determined the ransomware's process ID, the next logical step is to locate its origin. Where can we find the ransomware's executable file?

Also within the log, we can see the exact location of the ransomware executable file right next to the creation time. The origin of this stands out because we can see that this is installed in the C:\Users\Administrators, which indicates that this ransomware was started by an administrative account, which shows this was an account that was targeted and was the entry point of the attack. This can help narrow where we look for attack vectors in our investigation, such as if this was downloaded from an email, website, or elsewhere.



Question 4: Now that you've pinpointed the ransomware's executable location, let's dig deeper. It's a common tactic for ransomware to disrupt system recovery methods. Can you identify the command that was used for this purpose?

I solved this earlier in Question 1, where I deobfuscated the powershell command within claud ai. Once again, this is enumerating all Volume Shadow Copies, which are snapshots of windows system recoveries and backups, and then deletes them. So within the logs the powershell command looked like this:

powershell -e

RwBIAHQALQBXAG0AaQBPAGIAagBLAGMAAdAAgAFcAaQBuADMAMgBfAFMAaABhAGQAbwB3AGMAbwBwAHkAIAB8ACAARgBvAHIARQBhAGMAaAAAtAE8AYgBqAGUAYwB0ACAAewAkAF8ALgBEAGUAbABIAHQAZQAoACkAOwB9AA==

Using cyberchef or claud, it'll deobfuscate this base64 to

*** Get-WmiObject Win32_Shadowcopy | ForEach-Object {\$_.Delete();}**

Question 5: As we trace the ransomware's steps, a deeper verification is needed. Can you provide the sha256 hash of the ransomware's executable to cross-check with known malicious

signatures?

To get the sha256 hash I went into the query and typed:

index=revil "winlog.event_data.ProcessId"=5348 "winlog.event_data.Hashes"="*"

I went back and got the ProcessId of the ransomware, and searched for all hashes related that to that processid. From there, I was able to gather multiple hashes, including the sha256 hash, which is:

B8D7FB4488C0556385498271AB9FFDF0EB38BB2A330265D9852E3A6288092AA

Question 6: One crucial piece remains: identifying the attacker's communication channel. Can you leverage threat intelligence and known Indicators of Compromise (IoCs) to pinpoint the ransomware author's onion domain?

This one seemed like it bugged out, as I checked multiple sources, like virustotal, malwarebazaar, anyrun, but I was unable to find the domain. What I did was grabbed the sha256 hash and went to any.run to check all of the IOCs. From there, I should've been able to find the domain. As I found from other users, it should've be there. Within the domains, we can see that the domain came from:

aplebzu47wgazapdqks6vrcv6zcnjppkbr6wketf56nf6aq2nmyoyd.onion

The screenshot shows the ANY.RUN web interface for malware analysis. The top navigation bar includes 'CyberDefenders', 'CyberRange', 'Certifications', 'For Business', and 'Resources'. The main header area has 'ANY.RUN' and 'ANALYZE MALWARE' with sub-headers: 'Huge database of samples and IOCs', 'Unlimited submissions', 'Custom VM setup', and 'Interactive approach'. A 'Sign up, it's free' button is also present.

The main content area displays a table of network traffic. The table has columns for 'Process', 'IP', 'Host', 'Domain', and 'Reputation'. The data is as follows:

Process	IP	Host	Domain	Reputation
chrome.exe	142.251.140.77.443	accounts.google.com	GOOGLE	US
chrome.exe	224.0.0.251.5353	—	—	—
chrome.exe	142.251.140.67.443	update.googleapis.com	GOOGLE	US
chrome.exe	216.58.212.10.443	optimizationguide-pa.googleapis.com	—	—
chrome.exe	142.250.185.74.443	www.googleapis.com	GOOGLE	US

Below the network traffic table, there is a section titled 'DNS requests' with a table showing domain and IP addresses:

Domain	IP	Reputation
clientservices.googleapis.com	172.217.16.131	unknown
accounts.google.com	142.251.140.77	unknown
www.google.com	142.250.187.132	unknown
update.googleapis.com	142.251.140.67	unknown
aplebzu47wgazapdqks6vrcv6zcnjppkbr6wketf56nf6aq2nmyoyd.onion	—	unknown
google.com	142.251.36.238	unknown
optimizationguide-pa.googleapis.com	216.58.212.10	unknown
	216.58.212.42	unknown
	216.58.213.106	unknown

Final Thoughts

Overall Assessment

This lab was really helpful for getting better at Splunk. I'm definitely feeling a lot more confident now in finding IOCs and spotting evidence of bad actors in a network.

Initial Challenges & Solutions

When I started, I was struggling to find that first filename because I was just typing in queries trying to get an exact match. Then I realized using the "Interesting Fields" feature made everything way faster. Once I figured that out, the rest of the questions flowed pretty smoothly.

Key Learnings

I really enjoyed diving into the hash analysis piece. Throwing it into VirusTotal and AnyRun to see how this attack has been used in the wild gave me a much better picture of the whole thing. It's one thing to find an IOC, but seeing the real-world context of how attackers actually used it was pretty cool.

Confidence & Competency

Going through the whole attack timeline, connecting the dots, and validating everything through threat intel platforms definitely made me feel a lot more prepared for actual SOC work. This is something I genuinely enjoy and will continue to do more of it in the future.